



Asis Hang Rai

Syed Ahmed Sameeuddin

Bibek Chaudhary Tharu

CIO / Legal Officer

PRESENTATION AGENDA

What we'll cover in 10 minutes

① **Company Overview**

OilTech Innovations - who we are and what we do

② **Resources at Risk**

Technical, Physical, Human, Processes & Procedures

③ **Risk Assessment**

Asset inventory, TVA worksheet, vulnerability analysis

④ **Risk Management**

Avoidance, Transference, Mitigation, Acceptance

⑤ **Incident Response**

Ransomware spear-phishing scenario & IRP

Company Overview

OilTech Innovations - Perth, Western Australia

- **Location**

OilTech Innovations Tower,
Perth 6000 WA

- **Staff**

500+

- **SensorDrill**

Hardware & software for
oil/gas drilling
monitoring (licensed to
clients)

- **MeasureMe**

Hardware & software suite
for oil/gas pumping
monitoring (licensed)

- **Shake & Quake**

Internal seismic data
processing (clients submit
data, OilTech delivers
reports)

- **Market Share**

40%

- **Project 1 Upside**

\$100M

- **Project 2 Revenue**

\$30M

- **Tech Lead Advantage**

2 Years

RESOURCES AT RISK — TECHNICAL

Week 2 Workshop Content

Threat	Impact	Description	Countermeasures
APTs Targeting R&D	C, I	Long-term clandestine campaigns; Project 1 (\$100M) at risk from state-sponsored/competitor actors	Network segmentation, IDS/IPS
Ransomware on Admin Systems	I, A	Unpatched auto-update disabled systems; financial & HR data encryption risk	Backups + patching
DDoS on R&D Services	A	Simulation environments disrupted; product release delays	Traffic filtering
SQL Injection	C, I	Database-connected applications; financial data exposure & integrity compromise	Input validation
Unencrypted Backup Tapes	C	Open-rack tape storage in data processing room; client seismic data exposed	Encryption

RESOURCES AT RISK — PHYSICAL & HUMAN

Weeks 3 & 4 Workshop Content



- **Physical Threats**

Includes risks like unauthorized access to R&D labs, server rooms, and wiring closets, as well as unprotected backup tapes, laptop theft, and environmental hazards.

- **Human Threats**

Covers risks such as spear-phishing targeting researchers, insider threats from disgruntled employees, Business Email Compromise (BEC) for fraud, social engineering, and risks associated with contract staff and cleaners.

- **Countermeasures**

Proposed solutions include access control systems (keycards, CCTV, locked closets), security awareness training (SETA), and Role-Based Access Control (RBAC) with behavioral monitoring.

Implement robust access control, conduct regular security awareness training, and enforce Role-Based Access Control combined with behavioral monitoring to mitigate identified risks.

Resources At Risk: Processes & Procedures

Week 6 Workshop Content

- **R&D Risks**

No formal IP classification or data handling policy. Projects 1 & 2 lack access controls and labels.

- **Admin Risks**

No documented access provisioning/de-provisioning. Former staff may retain access.

- **Backup Integrity**

No backup verification procedure. Backup integrity unconfirmed; potential data loss.

- **Legal Risks**

No document retention & disposal policy. Risk of improper destruction or retention.

- **Privacy Breach Procedure**

Absence of a privacy breach notification procedure. Potential non-compliance with NDB scheme reporting deadlines.

- **Patch Management**

Auto-patching disabled on clients and servers, leaving vulnerabilities unpatched.

- **Recommended Fixes**

Implement data classification policy (ISO 27001), offboarding checklist, backup verification testing, and a breach notification procedure (NDB compliance).

Risk Assessment: Asset Criticality and Safeguards

Asset Ranking (Most Critical → Least Critical)

Asset	Description	Safeguards
V-1 Software IP & R&D Patents	Directly tied to competitive advantage and \$100M+ revenue potential.	S7, S6
V-2 Patented SW Operations Processes	Underpins SensorDrill, MeasureMe, and Shake & Quake.	S1, S2, S3, S4, S5, S7, S6
V-3 Engineering IP (Project 1 & 2)	Top-secret R&D; loss would eliminate technology lead.	S7, S6
V-4 SCM System	Supports software delivery and vendor management.	S1, S2, S3, S4, S5, S7
V-5 Operations & DB Servers	Support all business operations and client data processing.	S1, S2, S3, S4, S5, S9
V-6 Skilled Labour Force	Unique expertise; difficult to replace.	S7

The table outlines asset criticality and associated safeguards, highlighting the importance of protecting high-value intellectual property and operational systems.

RISK MANAGEMENT

Week 8 Workshop Content



- **AVOIDANCE: Unauthorised access to R&D data**

Controls: RBAC + data classification (ISO/IEC 27001); remove superfluous access. CBA: Control cost << \$100M asset value.

- **MITIGATION: IP loss following a successful breach**

Controls: Encrypted off-site DR backup; tested IR plan; routine DR testing to minimize recovery window.

- **MITIGATION: Credential compromise of Admin systems**

Controls: Mandatory MFA + documented password policy. Impact: Reduces credential-attack likelihood; improves MTBD/MTTR.

- **TRANSFERENCE: Third-party vendor breach**

Controls: Updated vendor contracts with liability clauses + cyber liability insurance. Impact: Shifts financial/legal exposure.

- **AVOIDANCE: Improper document retention & disposal**

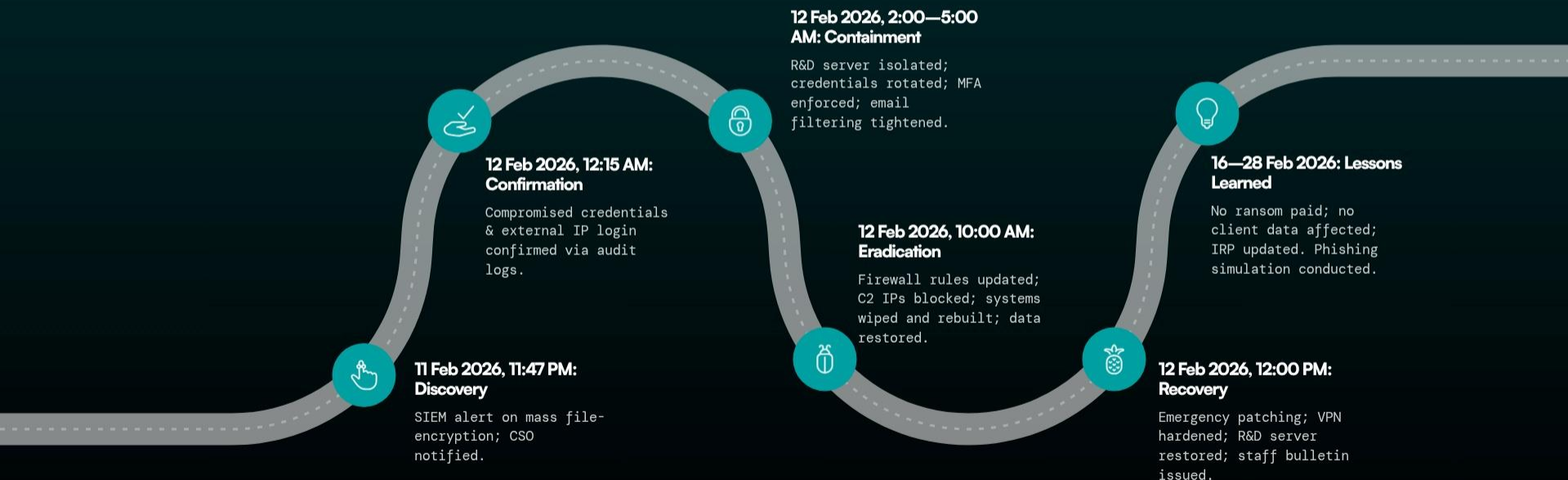
Controls: Formal retention schedule with destruction requirements + mandatory training. Impact: Closes procedural gap.

- **ACCEPTANCE: Minor procedural compliance audit failures**

CBA: Automated monitoring cost > expected loss. Manual periodic review. Reviewed annually.

Incident Response Plan - Ransomware Scenario

Timeline of Actions and Recovery



Key Takeaways



Threat Landscape

OilTech Innovations faces significant threats across R&D IP, Technical, Physical, Human, and Procedural resources, with R&D IP being the highest priority target.



Analytical Frameworks

Consistent application of CIA Triad analysis and TVA worksheet has identified six prioritized assets, mapped to threat agents and existing safeguards.



Risk Mitigation Strategy

Risk strategies align with ISO/IEC 27001:2022 and NIST SP 800-53. Key priorities include RBAC, MFA, and policy formalization.



Incident Response Success

The Incident Response Plan was successfully tested against a ransomware spear-phishing incident, demonstrating containment within 24 hours, an approximate cost of AUD \$45K, and no client data compromise.

REFERENCES

Academic & Industry Sources

- **ISO/IEC 27001:2022**

International Standard for Information Security Management Systems. Used to guide RBAC, data classification, and access control recommendations.

- **NIST SP 800-53 Rev. 5**

Security and Privacy Controls for Information Systems and Organizations. Applied to risk management strategy selection.

- **Delinea Incident Response Plan Template**

Industry IRP framework adapted for OilTech ransomware scenario. Sourced from Murdoch University LMS (Week 3).

- **Australian Privacy Act 1988 (NDB Scheme)**

Notifiable Data Breaches scheme obligations under the Office of the Australian Information Commissioner (OAIC).